B2B · AI GOVERNANCE · CYBERSECURITY

BEFORE THE RFP ARRIVES

The Small Supplier's Guide to **AI Risk Questionnaires**, **Evidence** and **Customer Trust**

AI QUESTIONNAIRES · EVIDENCE PACKS · HUMAN OVERSIGHT · CUSTOMER TRUST

ZIRLANDIA MILKOVIC

B2B · AI GOVERNANCE

BEFORE THE RFP ARRIVES

The Small Supplier's Guide to AI Risk Questionnaires, Evidence and Customer Trust

ZIRLANDIA MILKOVIC

Before the RFP Arrives

The Small Supplier's Guide to AI Risk Questionnaires, Evidence and Customer Trust

© 2026 Zirlandia Milkovic. All rights reserved. No part of this book may be reproduced without written permission, except for brief quotations in reviews.

First edition, 2026. Research cut-off: 11 November 2026. British English. Companion resource: GDPRGard.eu.

This book is practical guidance, not legal, security or data-protection advice. All examples, businesses and people in worked scenarios are fictional.

Contents

START HERE

Educational Disclaimer 4
Introduction: The Email on a Tuesday 4
Who This Book Is For 5
How to Use This Book 6
The Ten-Minute Readiness Check 6

CHAPTERS

1. The Questionnaire Is Coming 8
2. What Customers Are Really Asking 11
3. Know Your Own AI: The Inventory 14
4. Documenting Tools and Suppliers 17
5. Data Processing, Training and Retention 21
6. Evidence: What Customers May Ask to See 25
7. Explaining Human Oversight 28
8. AI-Related Contract Information 32
9. Classification and the EU AI Act for Small Suppliers 36
10. Avoiding Unsupported Claims 40
11. Answering the Questionnaire 43
12. Building the Trust Pack 47
13. When the Answer Is "Not Yet" 51

CLOSING

Conclusion: Before the RFP Arrives 54

APPENDICES

Appendix A: AI Inventory 55
Appendix B: Supplier and Sub-Processor Register 56
Appendix C: Evidence Index 57
Appendix D: Claim Register and Gap Register 58
Appendix E: Human Oversight Description Template 59
Appendix F: Forty Common Questions 60

BACK MATTER

Glossary 62
A Note on GDPRGard.eu 62
About the Author 64
Notes and Sources 65

Educational Disclaimer

This book is practical, educational guidance for small technology suppliers: software companies, consultants, marketing and creative agencies, and the freelancers and managed-service providers who sell to larger organisations. It is not legal, regulatory, audit or data-protection advice, and it does not create a professional relationship between the author and the reader.

AI regulation, contract practice and customer expectations are changing quickly. Dates, article numbers and standards named here were checked against the sources listed in the notes at the back, with a research cut-off of 11 November 2026, but several were read through secondary commentary rather than the official text. Before you rely on anything here for a decision that matters, such as a contract signature, a public compliance claim or a regulatory filing, check the current legal text and ask a qualified adviser.

Preparing good answers cannot guarantee you win a deal, pass a customer's review or satisfy a regulator. What it can do is make your answers accurate, consistent and evidence-backed, which is the thing you control.

Every business, person and questionnaire in a worked example is **fictional**. Product names, standards and regulations are real and are named so you can look them up. Where the book mentions a commercial toolkit or template, that is an observation, not an endorsement.

Introduction: The Email on a Tuesday

Tidewell Software has nine people and one product: scheduling software for small clinics. Last spring it added an AI feature that drafts appointment reminders and summarises patient messages for the receptionist. Customers liked it. Then Tidewell did what every small supplier hopes to do. It was shortlisted by a regional healthcare group with forty sites.

On a Tuesday afternoon, the group's procurement manager sent a spreadsheet. It had 142 questions and a three-week deadline. About thirty of them were about AI.

Which AI models does your service use, and who provides them? Is customer data used to train or improve any model? Where is it processed? Describe the human oversight applied to AI-generated outputs. List all sub-processors involved in AI features. Provide evidence of your AI governance policy. Confirm your compliance with the EU AI Act.

The founder, Marta, read it twice. She knew her product well. She did not have a list of the AI services it called. She was fairly sure the data was not used for training, but could not say where she had checked. She believed the receptionist always reviewed the drafts, but nothing recorded that. She had never written the words "AI governance policy" in her life. And she was uneasy about the last question, because she did not know what "confirm your compliance with the EU AI Act" would actually mean if someone later asked her to prove it.

She had three choices. She could answer quickly and optimistically. She could answer slowly and let the deal cool. Or she could do the thing this book is about: **build the answers before the questionnaire arrives**, so that when it does, filling it in takes days instead of weeks, and every sentence in it is true.

This is not a compliance book in the heavy sense. You will not be told to buy a certification or hire a consultancy. It is a working guide for people who sell to larger customers and have to prove, in writing, that they use AI sensibly. It covers:

- **What customers ask,** and why the questions are arriving now.
- **What to prepare:** an inventory of the AI you use, a register of the suppliers behind it, and a clear account of what happens to customer data.
- **What evidence looks like,** and the difference between a statement, a record and a certificate.
- **How to explain human oversight** without exaggerating it.
- **What contractual information to have ready,** from the data processing agreement to change notification and exit.
- **How to avoid unsupported claims,** the single most common and most expensive mistake.

The question this book keeps returning to is a plain one: *can I show it?* If you can, say so confidently. If you cannot yet, say that honestly and say what you are doing about it. Customers are far more forgiving of "not yet, and here is the date" than of an answer that later falls apart.

> **The rule.** Never write an answer you could not defend in a meeting with the customer's lawyer, using documents you could put on the table.

Who This Book Is For

This book is written for the people who actually receive these questionnaires and answer them, often alongside their day job:

- **Founders and managing directors** of small SaaS companies who are the sales lead, the product owner and the security contact at once.

- **Consultants and sole traders** who use AI tools in client work and are now asked how.
- **Marketing, creative and web agencies** that use generative AI in production and handle client data and brand assets.
- **Managed-service providers and software houses** whose customers sit in regulated sectors and pass their own obligations down the chain.
- **Sales, bid and operations staff** who are handed the spreadsheet because nobody else will take it.

A word on tone. Nothing here assumes you have been careless. Most small suppliers adopted AI tools quickly, for good reasons, and nobody gave them a manual for describing that adoption to a corporate buyer. Large customers, meanwhile, have been asked by their own regulators, insurers and boards to look harder at their suppliers. The questionnaire is the meeting point of those two pressures, and it lands on whoever is nearest the inbox.

How to Use This Book

You can read the book in an evening, or jump to what you need.

- **A questionnaire is already open on your desk?** Read Chapter 11, then Appendix F (forty common questions), and work backwards into the chapters you need.
- **Nothing has arrived yet?** Read the whole book in order and use the 90-day plan in Chapter 12. That is the intended route.
- **Worried about what you have already said?** Go to Chapter 10 and Appendix D, the claim register.
- **Need the contract side?** Read Chapter 8.
- **Not sure what the EU AI Act means for you?** Read Chapter 9, then the Notes.

Each chapter ends with a short action list. The appendices are designed to be copied into a spreadsheet and kept alive.

The Ten-Minute Readiness Check

Answer yes or no. Be honest; nobody is marking this.

1. Can you list every AI tool, model or service that touches customer data or customer deliverables in your business, today, without checking?
2. For each one, do you know who provides it, where it processes data, and under which contract terms?
3. Do you know whether any provider can use your customers' data to train or improve its models, and have you confirmed it in writing or in the settings?

4. Do you have a written, dated sub-processor list you could send to a customer today?
5. Do you have a short written AI-use policy that staff have actually seen?
6. If an AI-generated output reaches a customer, can you show who reviewed it and how?
7. Do you have a signed data processing agreement (or equivalent) with every provider that handles customer personal data?
8. Do you know which of your public statements about security, GDPR or AI could be challenged, and what evidence stands behind each?
9. Is there one named person who owns questionnaire answers, and a library of approved answers they can reuse?
10. If a customer asked tomorrow what you would do if an AI feature produced a harmful error, could you answer from a written process?

Scoring. Eight or more yes: you are ready to answer well, and this book will tighten the edges. Four to seven: you are typical, and the 90-day plan in Chapter 12 will close most gaps. Three or fewer: start with Chapters 3 and 4, because everything else depends on knowing what you use.

CHAPTER 1

The Questionnaire Is Coming

A quiet desk before the spreadsheet arrives. Preparation happens here, not in the deadline week

There is a moment in the life of every small supplier when the customers change. For a while you sell to people who can say yes on a call: a clinic manager, a marketing director, a small-business owner. Then one day you are shortlisted by an organisation with a procurement department, a legal team and a risk committee, and the way you are evaluated changes completely.

The first sign is usually a file. It might be called a *security questionnaire*, a *vendor due-diligence form*, a *third-party risk assessment*, or an RFP annex. It arrives as a spreadsheet, a portal login or a PDF, and for the last two years it has increasingly included a section on artificial intelligence.

Why the AI section appeared

Three pressures push the same questions down the supply chain.

Regulation. The EU AI Act (Regulation (EU) 2024/1689) places duties on the organisations that build, deploy and distribute AI systems, and its value-chain provisions expect providers to hand downstream users the information they need.[4] Even where your customer's own use of your product is not "high-risk", their legal and compliance teams now read every AI feature as a possible source of obligations. Meanwhile data-protection law has never been silent on this: when AI touches personal data, the GDPR's rules on processors, transfers, security and impact assessments apply.[6] Sector rules add more. Financial entities under DORA must manage ICT third-party risk by contract, and organisations under NIS2 must address supply-chain security.[7]

Insurance and governance. Boards and insurers want to know that the company's AI exposure is visible. Procurement teams are being given checklists that say "ask about AI" and are expected to file the answers.

A market that now sells the checklist. Dedicated AI vendor due-diligence packs appeared in 2026, some free and some paid. One European publisher sells a 32-question pack with eight contract clauses; an analyst firm has published an evaluation kit that maps vendor claims to ISO/IEC 42001, the NIST AI Risk Management Framework and the EU AI Act; blogs describe ten-document "evidence packs".[1][2][3] The point is not which of these your customer uses. The point is that **your customer can now buy a ready-made list of AI questions in an afternoon**, and a growing share of them do.

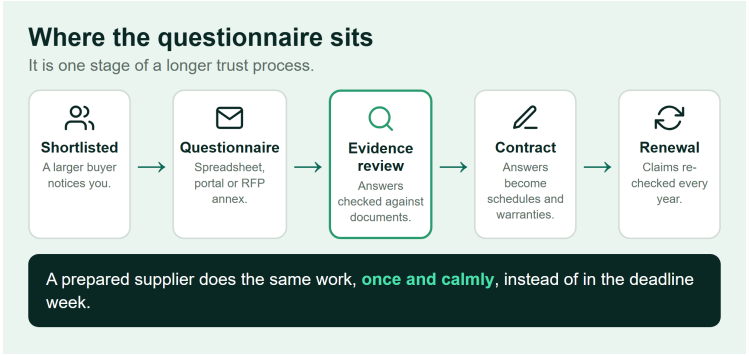
> **The rule.** The questionnaire is not hostile. It is a buyer trying to prove to *their* auditors that they asked. Help them do that, truthfully, and you become the supplier who is easy to approve.

What a questionnaire looks like

Questionnaires come in a few shapes. Knowing which you have changes how you answer.

Type	What it is	How to treat it
Bespoke spreadsheet	The customer's own list, 40 to 300 questions, often copied from older ones	Expect repeats and vague wording. Ask clarifying questions in writing.
Standard framework	A recognised set such as the SIG or CAIQ, sometimes with an AI add-on	Answers can be reused across customers. Keep a master copy.
AI addendum	A short extra section on models, data, oversight and the EU AI Act	The core of this book. Usually 15 to 40 questions.
RFP annex	Questions inside a tender with scoring and legal consequences	Answers may become contractual. Treat every sentence as a promise.
Portal or tool	An online platform where you answer and upload evidence	Evidence quality matters more than prose.

That last point matters. In many of these formats, a **claim without evidence scores zero**, and a claim contradicted by evidence is worse than no answer.



From a won shortlist to a signed contract: where the questionnaire sits

The cost of finding out late

Marta's three-week deadline sounds generous. In practice it vanishes quickly:

- Two days to find out who holds each answer (the person who built the integration may have left).
- Four days waiting for a provider to confirm where data is processed.
- A week to realise there is no written policy, and to write one in a hurry.
- Three days of legal review of answers that were written as marketing.

Suppliers who prepare in advance do the same work, but once, calmly, and keep it. They answer a new questionnaire in two or three days, with consistent text and a folder of evidence. Their reward is not only speed. It is **credibility**: the customer's reviewer sees the same careful pattern across every answer, and relaxes.

What this book will and will not do

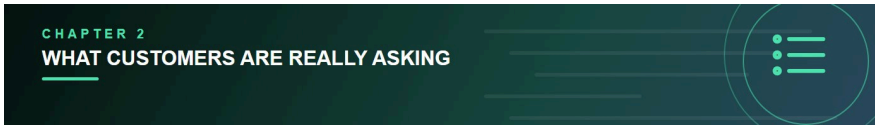
It will help you collect, organise and describe the facts about how you use AI, so that any questionnaire can be answered from a prepared base. It will not tell you what your customer's contract must say, grant you a compliance status, or replace legal advice. Where a question needs a lawyer, the book says so.

Action list

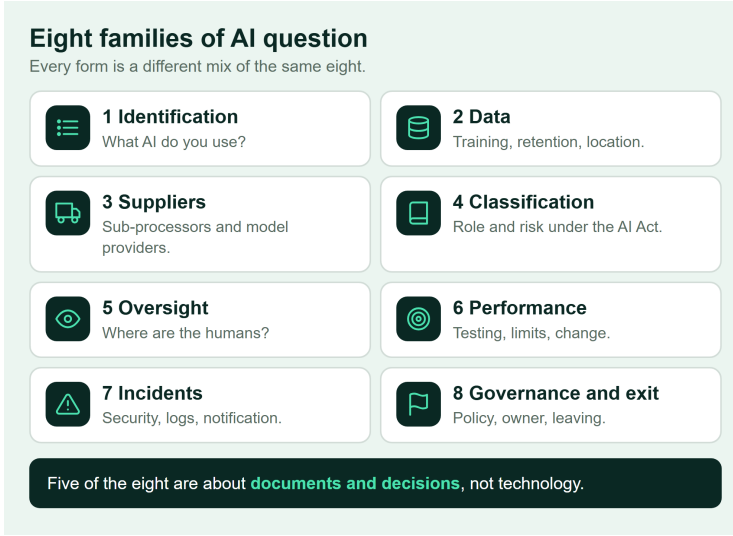
- ☐ Search your inbox for the last security or vendor form you received. Keep it as a sample.
- ☐ List your three largest current or hoped-for customers and ask which of them will send a form.
- ☐ Name one person who will own questionnaire answers from now on.

CHAPTER 2

What Customers Are Really Asking



Questionnaires look different but ask the same underlying things. If you understand the eight families of AI question, you can recognise any form and map it to a prepared answer.



The eight families of AI due-diligence question

The eight families

1. Identification. *What AI do you use?* Models, providers, features, versions, and whether the AI is your own, a third party's, or a mixture. Customers want a list, not a paragraph.

2. Data. *What happens to our data?* What goes into the AI, where it is processed, how long it is kept, whether it is used for training, and who can see it.

3. Suppliers. *Who else is involved?* Sub-processors and model providers, their locations, and how you assess them.

4. Classification and law. *How do you view your obligations?* Whether you are a provider or deployer under the AI Act, how your features are classified, and what you do about transparency and literacy.

5. Oversight. *Where are the humans?* Who reviews AI outputs, who can override, and what happens when a person disagrees with the machine.

6. Performance and change. *How do you know it works, and what happens when it changes?* Testing, accuracy limits, model updates, and how you tell customers.

7. Security and incidents. *What if something goes wrong?* Access control, logging, monitoring, and a process for AI-specific incidents, plus how fast you notify.

8. Governance and exit. *Who is accountable, and how do we leave?* Policy, ownership, training, and what happens to customer data if the contract ends.

Notice how many of these are not about technology at all. Five of the eight (suppliers, classification, oversight, incidents, governance) are about **documentation and decision-making**. A small company can be excellent here. You do not need a large budget to have a clear list, a short policy and a named owner.

What a good answer has in common

Look at two answers to the same question, *"Is customer data used to train AI models?"*

> **Weak:** "We take data privacy very seriously and do not misuse customer data."
>
> **Strong:** "No. Customer content is sent to [Provider] through its business API under terms that exclude customer data from model training (Provider terms, section X, reviewed 4 Nov 2026; copy in evidence folder E-12). We do not fine-tune any model on customer data. We review this setting quarterly. Owner: Head of Operations."

The strong answer is not longer because it is wordier. It is longer because it contains **four things every good answer contains**: a direct answer, the basis for it, a date, and an owner. Train yourself to include all four.

The questions behind the questions

Reviewers read answers for patterns. A few signals tend to raise or lower confidence quickly:

- **Specific nouns.** Named providers, named regions, named documents. Vague language such as "industry-leading" lowers trust.
- **Consistency.** The same fact appears in the privacy notice, the DPA, the questionnaire and the sales deck, and never differently.
- **Calibrated honesty.** "We do not do X yet, and we will by March" reads better than a suspiciously perfect column of "Yes".
- **Evidence references.** Every claim points to something.

- **Appropriate scope.** An answer about the whole company when the question was about one feature, or the reverse, suggests the writer is guessing.

A note on the AI Act question

Almost every AI addendum includes some form of "*Confirm your compliance with the EU AI Act*". Treat this as a question about **how you have classified your position**, not a request for a certificate. There is no general "AI Act compliance certificate" that a small supplier can hold, and the Act applies differently depending on your role, the features you offer and their risk category. Chapter 9 gives you a way to answer it accurately.

Action list

- ☐ Read through one real questionnaire and tag each question with one of the eight families.
- ☐ Count how many are about documents and decisions rather than technology. That is your preparation workload.
- ☐ Write down the four elements of a good answer where you will see them.

CHAPTER 3

Know Your Own AI: The Inventory

Before anything else, an honest list of what you use

Every other chapter depends on this one. You cannot describe your oversight, your suppliers or your data flows if you do not know which AI tools exist in your business. Surprisingly, this is where most small suppliers stall.

Two kinds of AI to list

AI inside your product. Features your customers use: summarisation, drafting, classification, recommendations, chat, search, transcription, scoring. Include features that call a third-party model by API, and features built on open models you host yourself.

AI inside your business. Tools your team uses to do their work: coding assistants, writing tools, meeting transcribers, design generators, customer-support bots, spreadsheet copilots, browser extensions. Some of these touch customer data. Many were adopted informally.

Customers ask about both. A questionnaire that says "AI used in service delivery" is reaching for the second list, and it often catches suppliers off guard.

Shadow AI

Within any team of more than three people, there is AI that nobody told the owner about. A designer uses an image generator. A developer pastes code into a chatbot. An account manager uses a note-taking app in client calls. None of it is sinister. It is simply invisible, and the inventory exists to make it visible.

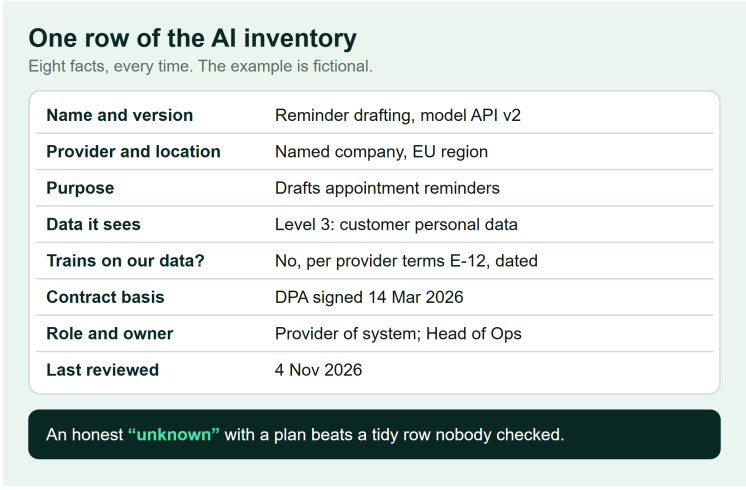
The best method is not an investigation. It is a short, friendly message:

> *We are putting together a list of every AI tool we use at work, so we can answer customer questions accurately. No one is in trouble. Please reply with anything you use, even occasionally, and whether it ever sees customer information.*

Follow up in a team meeting, and check expense claims and browser-extension lists for tools people forgot to mention.

What the inventory records

For every AI tool or feature, record the same small set of facts. These are the fields reviewers will ask for, in roughly this order.



One row of the AI inventory: the facts every entry needs

Field	What to write
Name and version	Tool, model family, plan or tier
Provider and location	Legal entity and where it processes data
Purpose	What it is used for, in one line
Used in	Product feature, internal use, or both
Data it sees	Categories: none, business, personal, special-category, customer confidential
Training on your data?	Yes, no, opt-out set, unknown (with source)
Contract basis	DPA signed, standard terms, free-tier terms
Owner	One named person
Last reviewed	Date

The "unknown" answers are valuable. A list with honest unknowns and a plan to resolve them is a stronger starting point than a perfect-looking list that nobody checked.

Classify what each tool sees

A simple four-level scale is enough to start:

1. **No business data.** Public or generic content only.
2. **Internal business data.** Not customer-related.
3. **Customer content or personal data.** The level that triggers most questions.
4. **Special-category or highly sensitive data.** Health, biometric, children's data, financial credentials.

Any tool at level 3 or 4 needs a contract, a settings review and an entry in your supplier register (Chapter 4). Any tool at level 4 deserves a conversation about whether it should be there at all.

Free-tier and personal accounts

The riskiest line in a typical inventory is a tool used on a **free or personal account**. Terms differ between consumer and business tiers, and a free tool may allow your inputs to be used for improvement unless you opt out. If staff use personal accounts for client work, you cannot answer the training question truthfully, because you do not control the settings. The fix is boring and effective: provide approved business accounts, and say in your policy that personal accounts are not for client data.

Keep it alive

An inventory that is accurate once and never touched is a liability, because it becomes the document that contradicts reality. Build in three habits:

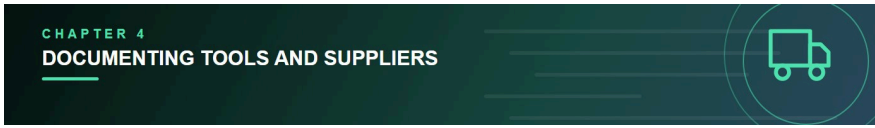
- **A review date** on every row, with a quarterly check.
- **A rule** that no new AI tool touches customer data until it is on the list.
- **A trigger** to update the inventory when a provider changes terms or a new feature ships.

Action list

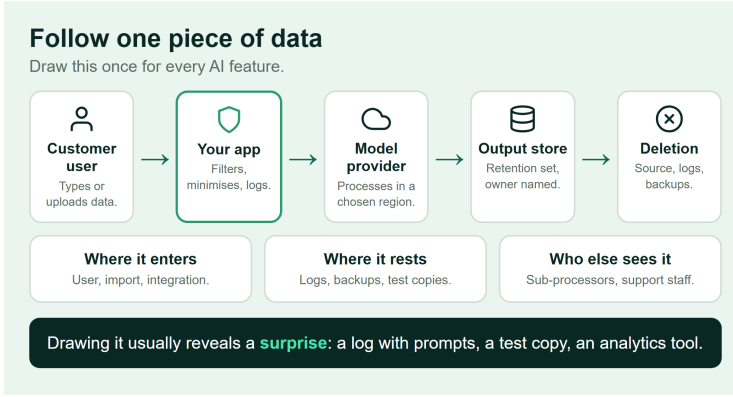
- ☐ Send the "list your AI tools" message today.
- ☐ Build the inventory using Appendix A.
- ☐ Mark every level-3 and level-4 tool and note whether its settings were checked.
- ☐ Move client work off free and personal accounts.

CHAPTER 4

Documenting Tools and Suppliers



Customers do not only buy from you. They buy from everyone you rely on. When a model provider in another country processes a patient message, the customer's risk includes that provider. The questionnaire's job is to trace the chain, and your job is to have the chain drawn already.



Where customer data travels when an AI feature runs

Draw the data path

Take each AI feature in your product and trace one piece of customer data from the moment it enters to the moment it is deleted. A short, simple diagram beats a paragraph. It should show:

- **Where the data enters** (the user, an import, an integration).
- **What you do to it** before it reaches the AI (filtering, minimising, pseudonymising).
- **Where it goes** (which provider, which region, which API).
- **What comes back** and where outputs are stored.
- **How long each stage keeps it,** and where logs are held.

Do this once for each feature. Most small suppliers find that drawing the diagram reveals at least one surprise: a log file that stores prompts, an analytics tool that receives text, a test environment with real data.

The supplier register

Alongside the diagram, keep a **supplier register**: one row for every third party that touches customer data or provides AI capability. It overlaps with the inventory but is organised around the relationship, not the tool.

Field	Why a customer asks
Legal entity and country	Jurisdiction, applicable law
Service provided	What would stop if they failed
Data categories handled	Scope of exposure
Processing locations	Transfer and residency questions
Sub-processors they use	The chain beyond your direct supplier
Contract and DPA status	Whether the relationship is documented
Security evidence held	Certificates, audit reports, trust pages
Date last reviewed	Whether the register is alive
Exit route	What you would do if you had to replace them

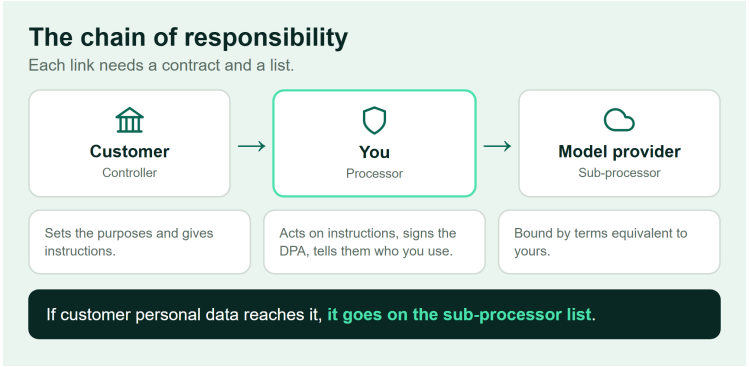
Appendix B provides a template. A register of ten rows, kept current, is worth more than a hundred-row export nobody has read.

Provider, sub-processor, subcontractor: what to call them

Terms get tangled in questionnaires, and answering the wrong question is a common slip.

- A **processor** handles personal data on your customer's behalf. If you provide a service that processes customer personal data, *you* are a processor, and the customer is the controller.
- A **sub-processor** is a processor *you* engage to help you do that. Under the GDPR you generally need the controller's authorisation, and you must bind the sub-processor to equivalent obligations.[6]
- A **subcontractor** is a broader word for anyone you pay to deliver part of your service, whether or not they touch personal data.
- A **model provider** is the company that supplies the underlying AI model. If its model processes your customers' personal data through your product, it will usually be a sub-processor.

The practical rule: **if customer personal data reaches it, it goes on the sub-processor list.** A customer who later finds an undeclared sub-processor will not care how small it was.



The chain of responsibility: customer, you, your providers

What to gather from each provider

For every provider on the register, build a small file. Most of it can be collected in an hour from public pages.

- **Terms of service and data processing addendum,** dated and saved as PDFs, because web pages change.
- **Data-use and training statement.** The page or clause that says whether customer inputs are used to improve models, and under which plan.
- **Security evidence.** A trust page, SOC 2 report summary, ISO/IEC 27001 certificate, or penetration-test letter.
- **Sub-processor list** and the provider's change-notification method.
- **Region options** and which one you have selected.
- **Retention settings** (including abuse-monitoring retention, which some providers apply even when training is off).
- **Incident contact** and the committed notification period.

Save these into a folder per provider and record the date you collected them. Terms change; evidence must carry a date.

Beware the settings drift

A provider that offered a zero-retention option in January may have changed the default in July. A feature you switched off may have been renamed. This is why the register records **date last reviewed** and why a quarterly check is worth the hour. When a questionnaire asks "is your answer still accurate?", you want to be able to say when you last confirmed it.

Open models and self-hosting

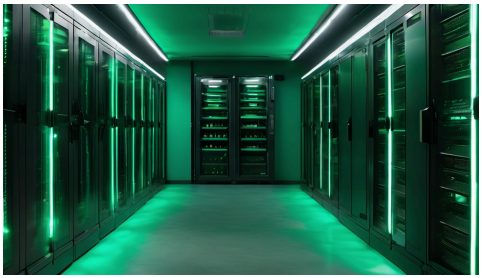
If you run an open-weight model on your own infrastructure, your supplier chain looks different: the model's licence matters, the hosting provider becomes the key sub-processor, and customer data never leaves your environment. This can be a strong answer on data location, but it moves responsibility for security, updates and evaluation onto you. State this honestly. Customers appreciate the data-residency benefit and will ask who patches the system.

Action list

- ☐ Draw a data-path diagram for each AI feature.
- ☐ Build the supplier register (Appendix B) with at least the ten providers that matter most.
- ☐ Download and date each provider's terms, DPA and data-use statement.
- ☐ Publish or prepare a clean sub-processor list you can send on request.

CHAPTER 5

Data Processing, Training and Retention



Behind every AI feature is infrastructure that someone, somewhere, operates

If you read a hundred AI questionnaires, the same four words appear in the first few lines: *train*, *retain*, *where* and *who*. Customers want to know whether their data teaches a model, how long it stays, where it sits, and who can read it. Most of the answers already exist in your provider contracts. The work is finding them and stating them plainly.

Start with roles

Your answers depend on the role you play, so settle that first.

- **Customer personal data processed to deliver your service:** you are normally a **processor**, acting on the customer's documented instructions, with the customer as **controller**. Your obligations come from the GDPR's processor rules and from the contract.[6]
- **Your own data about your own staff, leads and website visitors:** you are a **controller**, and the AI tools you use on that data are your processors.
- **Mixed situations** exist. If you decide for your own purposes to use customer data to improve your product, you may have stepped into controller territory for that use, and the customer needs to know. Regulators look at who decides the purposes and means, not at what the contract calls you.[14]

Getting the role right matters because it determines what you may do with the data. A processor who quietly uses customer content to improve a general AI model is usually outside its instructions.

The training question

Is our data used to train or improve AI models? This is the most sensitive question in the form, and it has three parts, all of which you should answer separately.

1. **Your own models.** Do you fine-tune or train any model on customer content? If yes: with what permission, for what purpose, and can the customer opt out?
2. **Your providers' models.** Under the plan and settings you use, may a provider use your inputs and outputs for training or improvement?
3. **Derived data.** Do you keep prompts, outputs, embeddings or evaluation sets drawn from customer data? Embeddings and test sets are still derived from customer content.

Many business and API tiers exclude customer data from training by default; free and consumer tiers often do not. **Do not answer from memory or from a sales page.** Open the contract and settings, capture the clause and date, and file it. The European Data Protection Board has also published an opinion on when AI models trained on personal data can be considered anonymous and on legitimate interest as a legal basis, which is a reminder that "it is only used to improve the model" is not an automatic safe harbour.[13]

Retention, in layers

A single "retention period" is rarely the whole truth. Data lives in layers, and a thorough answer covers each:

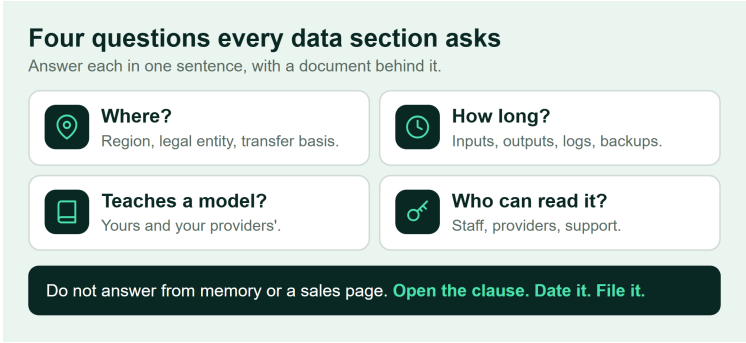
Layer	Examples	Typical question
Inputs	Prompts, uploaded files	Stored by you? By the provider? How long?
Outputs	Generated text, summaries	Where saved, for whom?
Logs	Request logs, error traces, audit trails	Do they contain personal data?
Provider monitoring	Abuse and safety review copies	Is there a short retention window, and can it be disabled?
Backups	Snapshots, archives	How long until deleted data leaves them?
Derived data	Embeddings, search indexes, test sets	Are they deleted with the source?

If you cannot state a figure for a layer, write "we are confirming this with [provider]" and then do so. An honest gap is better than an invented number.

Location and transfers

Where is our data processed? Give the answer in terms of **regions and legal entities**, not slogans. "Processed in the EU" needs a provider-confirmed basis: the region selected, the entity operating it and whether support staff elsewhere can

access data. If any processing happens outside the EU or EEA, customers will ask how the transfer is covered, for example by an adequacy decision, the EU–US Data Privacy Framework for certified recipients, or standard contractual clauses.[15] That framework has been challenged in court, so confirm its current status rather than relying on an old answer.



Four questions every data section tries to answer

Access: who can read it?

Beyond location, customers ask who has access. Be ready to say:

- Which of your staff can see customer content, and under what authorisation.
- Whether provider employees can review prompts, and in which circumstances (for example abuse investigation).
- How access is logged and reviewed.
- Whether customer data is ever used in non-production environments such as testing or demos.

DPIAs and the customer's own duties

Some customers will say they need to complete a data protection impact assessment for a feature you provide. They will ask for information to help. A short **DPIA support note**, covering the purpose, data categories, data path, safeguards and residual limits of each AI feature, saves everyone time and shows maturity. Remember that the assessment belongs to the controller. Your job is to give accurate inputs, not to declare the result.[6]

A sample answer set

Training. "We do not train or fine-tune any model on customer content. Our model provider's business terms exclude customer inputs and outputs from training (clause reference, dated). Prompts and outputs are retained for [30] days for support and then deleted; provider abuse-monitoring retention is [30] days (provider page, dated). Owner: Head of Operations. Reviewed quarterly."

Replace the bracketed numbers with real ones. If you do not have them, you are not ready to send this answer.

Action list

- ☐ For each AI feature, write one sentence stating your role and the customer's.
- ☐ Capture the training clause and date for every provider that sees customer data.
- ☐ List every layer where customer data is stored and state a retention period for each.
- ☐ Confirm processing region, and keep the provider's confirmation.

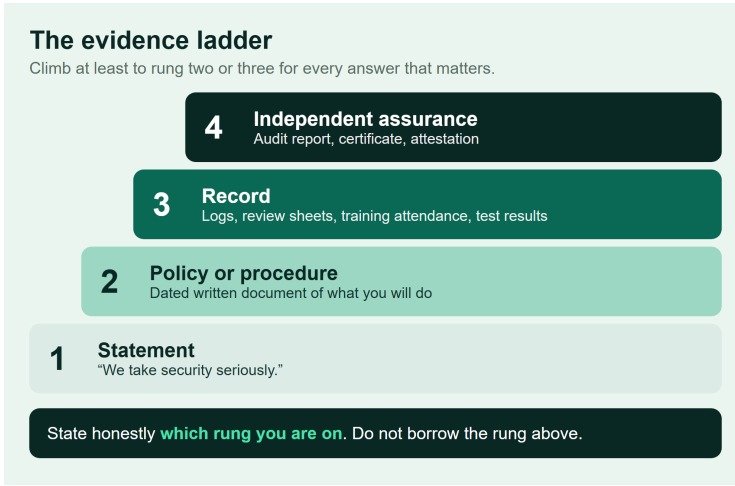
CHAPTER 6

Evidence: What Customers May Ask to See

A customer who reads "we take security seriously" has learned nothing. A customer who reads "our incident procedure is in document IR-3, last tested on 12 October, with the exercise record attached" has learned something they can file. The difference is evidence.

The evidence ladder

Not all evidence is equal. It helps to think in four rungs, from weakest to strongest.



The evidence ladder: the higher the rung, the more a customer can rely on it

1. **A statement.** "We do not train on customer data." Costs nothing to write, and tells the reader only what you believe.
2. **A policy or procedure.** A dated written document that says what you will do. It proves intent and structure, not behaviour.
3. **A record.** Logs, review sheets, training attendance, test results, tickets. Proof that something *happened*.
4. **Independent assurance.** An audit report, certificate or attestation from a third party, such as ISO/IEC 27001, a SOC 2 report or an ISO/IEC 42001 certificate.[8]

You will not have rung four for everything. You do not need it. What you need is to **climb at least to rung two or three for every answer that matters**, and to be honest about the rung you are on.

What customers actually request

Across questionnaires, the same documents are requested again and again. A small supplier can build most of them in a few weeks:

Document	Rung	What it shows
AI inventory	2	You know what you use
Sub-processor list	2	Your chain is documented
AI acceptable-use policy	2	Staff have rules
Data processing agreement	2	The legal basis for processing
Provider terms and training exclusions	2	The basis for your data claims
Security policy and access control summary	2	A baseline of controls
Incident response procedure	2	A plan exists
Incident exercise record	3	The plan has been tried
Human-review records or sample logs	3	Oversight happens
Staff AI-awareness training record	3	People were told
Penetration-test summary	4	Independent testing
ISO/IEC 27001 or SOC 2 report	4	Independent control assurance
ISO/IEC 42001 certificate	4	An audited AI management system

A stamped document is not the same thing as a verified claim

About certificates

A small supplier will often be told, or will wonder, whether it needs a certification. A few honest points.

- **ISO/IEC 27001** (information security) and **SOC 2** are the most commonly requested assurances. If you already hold one, it is your strongest piece of evidence, and you should be careful to state its **scope** accurately. A certificate

covering one product or office does not cover the whole company.

- **ISO/IEC 42001:2023** is the first certifiable standard for AI management systems. It is a real option and a credible signal, but certification is a project with costs and an audit, and it is not required by law. As commentators note, it does not by itself establish conformity with the EU AI Act.[8]
- The **NIST AI Risk Management Framework** and its Generative AI Profile (NIST AI 600-1) are voluntary guidance, not certifications. You can say you *align with* or *use* them as a reference, never that you are "NIST certified".[9]
- The **Cloud Security Alliance's AI Controls Matrix**, updated to v1.1 in July 2026, is a control framework in 18 domains that underpins the STAR for AI programme. It is useful as a checklist even if you never pursue the programme. [10]

If a certificate is not realistic this year, a short **self-assessment against a recognised framework**, honestly scoped and dated, is a respectable interim. Label it as a self-assessment.

Building the evidence index

Evidence you cannot find in ten minutes does not exist in a deadline week. Create an **evidence index**: a simple sheet with a short ID for each document (for example E-01), its title, date, owner, where it is stored and which questionnaire topics it supports (Appendix C). Then every answer in your library can end with "Evidence: E-07, E-12".

Two rules keep the index trustworthy:

- **Every evidence file carries a date** in its name or header.
- **Nothing is shared that you have not reread this quarter.** An out-of-date policy is worse than none, because it documents a promise you are not keeping.

What not to put in the evidence pack

Do not send raw logs containing customer data, internal architecture diagrams with exploitable detail, credentials, or other customers' names. Share summaries, redacted samples and documents suitable for sharing under a confidentiality agreement. Where a customer asks for more, offer a call or a supervised review instead of an attachment.

Action list

- ☐ Start the evidence index with the documents you already have.
- ☐ Mark each by rung and note the weakest answers it supports.
- ☐ Choose the three missing documents customers most often request and write them first.
- ☐ Check the exact scope wording of any certificate before quoting it.

CHAPTER 7

Explaining Human Oversight

Oversight is a working process, not a sentence in a policy

"Describe the human oversight applied to AI-generated outputs." This question is deceptively hard, because the honest answer is usually more modest than the one that sounds best. A founder wants to write "every output is reviewed by an expert". Then a customer asks to see the review log.

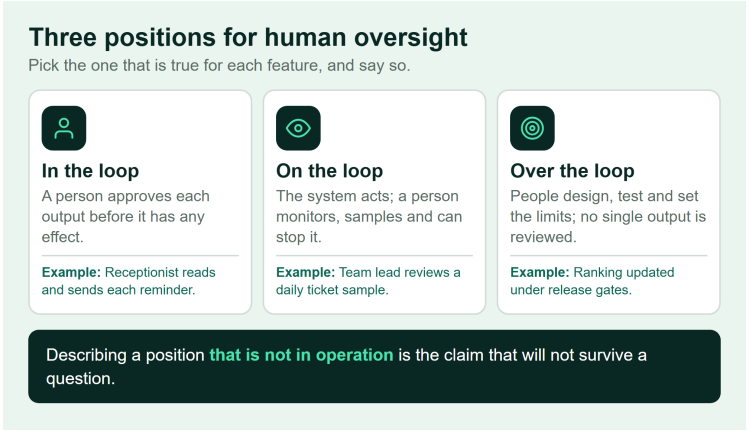
Why customers ask

There are three reasons, and good answers address all of them.

- **Legal.** For high-risk AI systems, the AI Act requires systems to be designed so that natural persons can oversee them effectively, and requires deployers to assign oversight to people with the necessary competence, training and authority.[4] Most small-supplier features will not be high-risk, but customers ask the question anyway, to see how you think.
- **Operational.** A buyer wants to know whether an AI mistake in your product reaches their patients, customers or staff unchecked.
- **Accountability.** If something goes wrong, who is responsible, and can they show they were paying attention?

Three positions, honestly named

It helps to describe oversight using three plain positions. Pick the one that is true for each feature, and say so.



Three positions for human oversight: in the loop, on the loop, over the loop

Human in the loop. A person reviews and approves each output before it has any effect. Example: the receptionist reads each AI-drafted reminder and presses send.

Human on the loop. The system acts on its own, and a person monitors, samples and can intervene or stop it. Example: AI-categorised support tickets go straight into queues, while a team lead reviews a daily sample and the error rate.

Human over the loop. People design, test and govern the system and set its limits, but no individual output is reviewed. Example: an AI search ranking that updates continuously, controlled by evaluation and release gates.

None of the three is "wrong". Each suits different risks. What is wrong is **describing a position that is not in operation**. "Human in the loop" applied to a button nobody reads is a claim that will not survive a question.

Automation bias

A person who reviews many outputs and finds nearly all of them correct will start approving by habit. This is well known, and a thoughtful reviewer on the customer side will ask how you guard against it. Good answers mention a few concrete measures:

- Making the AI's uncertainty or sources visible beside the output.
- Requiring an active edit, tick or reason on higher-risk items, not just a default "approve".
- Mixing in known-bad test items to check reviewers are paying attention.
- Reviewing the override rate: a rate of exactly zero deserves suspicion.
- Giving reviewers time and a way to escalate.

What to document

You do not need an elaborate programme. For each AI feature, write a half-page **oversight description** using the template in Appendix E, covering:

1. **The position** (in, on or over the loop) and who holds it.
2. **The reviewer's role,** training and authority to reject or stop.
3. **What the reviewer sees,** including limitations and confidence.
4. **What is recorded:** approvals, edits, overrides, timestamps.
5. **What happens on disagreement or error:** the escalation path and how fast.
6. **How the process is tested:** sampling, audits, user feedback.
7. **Known limits:** where the AI is not suitable for use.

Then make sure the product actually produces some of those records. A review log that exists only in the policy is not evidence.

Transparency to end users

Oversight is related to, but not the same as, telling people they are dealing with AI. Where a feature interacts with people or generates content, the AI Act's transparency rules (Article 50) generally require disclosure that the person is interacting with an AI system, and marking of certain synthetic content. These duties began to apply on 2 August 2026, with a grace period to 2 December 2026 for certain marking obligations on systems already on the market.[4][5] Whether the duty falls on you or on your customer depends on who provides and who deploys the system. Say so in the questionnaire, and give customers the information they need to make their own disclosure.

A model answer, with honest limits

"*Reminder drafts are generated by an AI model and are always reviewed and sent by a trained receptionist; nothing is sent automatically (human in the loop). The reviewer can edit or discard any draft. The interface shows a banner marking the text as AI-generated. We log the reviewer, time and whether the text was edited. Message summaries are advisory only and are not used for clinical decisions; the original message is always shown beside the summary. We sample 50 drafts a month for quality and review the edit rate. We have not evaluated the feature for use in triage and do not offer it for that purpose.*"

Notice the final sentence. **Stating what the feature is not for** is one of the most credible things a supplier can write.

Action list

- ☐ For each AI feature, choose in, on or over the loop and write one honest sentence.

- ☐ Complete an oversight description (Appendix E) for your most important feature.
- ☐ Check the product actually records approvals and overrides, and keep a sample.
- ☐ Write the "not suitable for" line for each feature.

CHAPTER 8

AI-Related Contract Information

The questionnaire answers become the facts behind the contract

Questionnaires and contracts are two halves of one process. The answers you give in the first often become schedules, warranties or representations in the second. This chapter is about having the contractual information ready, so you are not inventing terms under pressure. It is not legal advice; your lawyer should review anything you sign.

The documents a customer may expect

A corporate customer will usually ask for some combination of these. Prepare each as a clean, reviewed template.

Data processing agreement (DPA). The GDPR requires a contract between controller and processor that sets out the subject matter, duration, nature and purpose of processing, data types and the processor's obligations, including security, sub-processing, assistance and deletion.[6] Prepare your standard DPA, and make sure your own provider DPAs back it up.

Sub-processor list and change-notice mechanism. Customers expect an up-to-date list, a way to be told of changes, and a period to object. Decide how you will notify (email, portal or webpage) and how many days' notice you can really give.

AI-specific terms. A short schedule or addendum that covers what the AI features do, what data they use, whether customer data is used for training, and any usage restrictions.

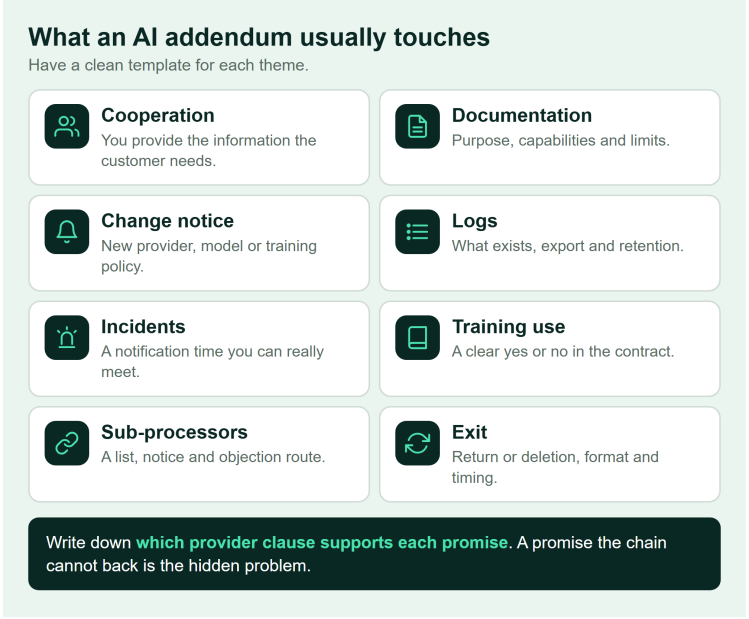
Security schedule. A summary of technical and organisational measures, matching what you already say elsewhere.

Service levels and support. Availability commitments and how AI features are covered, including what happens when a model provider has an outage.

The clauses AI customers ask about

Packs sold to procurement teams tend to converge on a similar clause list. Whether or not your customer uses one, expect these themes:[1]

- **Cooperation.** You will provide the information the customer needs to meet its own obligations, such as documentation about the system.
- **Technical documentation.** What you can share about how the AI feature works, its purpose, capabilities and limits.
- **Change notification.** You will tell the customer before material changes: a new model provider, a new sub-processor, a changed training policy, a significant change in behaviour.
- **Logs.** Which logs exist, how customers can export them and how long you keep them.
- **Incident notification.** A defined timeframe for telling the customer about a security or serious AI incident.
- **Bias and data governance.** How training or evaluation data is managed where relevant.
- **Use of customer data for training.** A clear yes or no, in the contract and not only in a policy.
- **Exit.** Return or deletion of data, the format, and the timing, including data held by sub-processors.



The contract clauses an AI addendum usually touches

Why "cooperation" matters most

In the AI Act's value-chain provisions, a provider of a high-risk system must work with those who supply or integrate components, and general-purpose-model providers must make documentation available to downstream providers.[4] Even where none of that applies to you, it reveals the logic buyers follow: **they want the right to ask you for information, and a promise that you will answer.** A cooperation clause is cheap to agree to and expensive to refuse. A flat refusal to cooperate is the kind of answer that ends a review.

Flow-down and flow-up

Your customer's obligations may require you to accept terms from *them*, for example audit rights, security requirements or incident timelines. Likewise your obligations to them must be backed by terms from *your* providers. Check the chain in both directions:

- **Flow-down:** if you promise a customer 24-hour incident notice, can your model provider's contract support it? If your provider promises 72 hours, you cannot honestly promise 24 hours *of the provider's incidents*.
- **Flow-up:** can you pass a customer's deletion request to every sub-processor, and in what time?

A promise you cannot back up through the chain is the most common hidden problem in AI contracts. Write down, for each commitment, which provider clause supports it.

Liability and IP, in plain terms

Two topics regularly surprise small suppliers. Do not negotiate them blind.

- **Liability for AI output.** Customers may ask you to take responsibility for harms caused by AI features. Read the limitation of liability, check whether your provider limits its own liability to you, and avoid accepting more than you can recover. If you are unsure, talk to your insurer and your lawyer first.
- **Intellectual property.** Customers may ask who owns outputs, whether outputs infringe third-party rights, and whether you offer an indemnity. Providers differ in what they offer. Do not promise a stronger indemnity than your own provider gives you.

Negotiating from your information

When you have the documents ready, negotiation becomes a conversation about specifics. Offer your standard terms first, be clear about what you can change and what you cannot, and distinguish between **commitments** (we will do this and be liable) and **statements of current practice** (we do this today, subject to change on notice). Customers accept the second kind more readily, and it keeps you out of promising what you cannot guarantee.

Action list

- ☐ Gather your DPA, sub-processor list, AI addendum and security schedule into one folder.
- ☐ For each commitment you make (incident timing, deletion, notification), note the provider clause that supports it.
- ☐ Draft a one-page "AI terms at a glance" that matches your questionnaire answers.
- ☐ Ask your lawyer to review liability and IP wording once, then reuse it.

CHAPTER 9

Classification and the EU AI Act for Small Suppliers

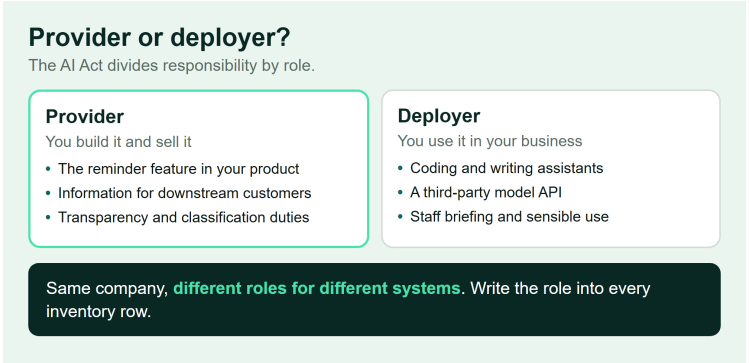
"Confirm your compliance with the EU AI Act." Few sentences in a questionnaire cause more nervous typing. This chapter gives you a calm way to answer it. It is a practical orientation, not a legal opinion, and anything that decides a contract or a public statement should be checked with a qualified adviser against the current text.

Start with your role

The AI Act divides responsibility by role. The two that matter most to a small supplier are:

- **Provider:** the organisation that develops an AI system (or has one developed) and places it on the market or puts it into service under its own name. If you build an AI feature into your product and sell it, you are very likely a provider of that system.
- **Deployer:** the organisation that uses an AI system under its own authority in a professional context. If you use a third-party AI tool in your agency to produce client work, you are a deployer of that tool.

You can be **both**, for different systems. Tidewell is a *deployer* of its coding assistant and of the model API it calls, and a *provider* of the reminder feature it built on that API. Another set of roles sits upstream: the company that supplies the underlying **general-purpose AI model** has its own obligations, including making documentation available to downstream providers.[4]



Providers and deployers: the same company, different roles for different systems

Write your role for each system into the inventory. It is the single most useful column when someone asks about the Act.

Then, the risk tier

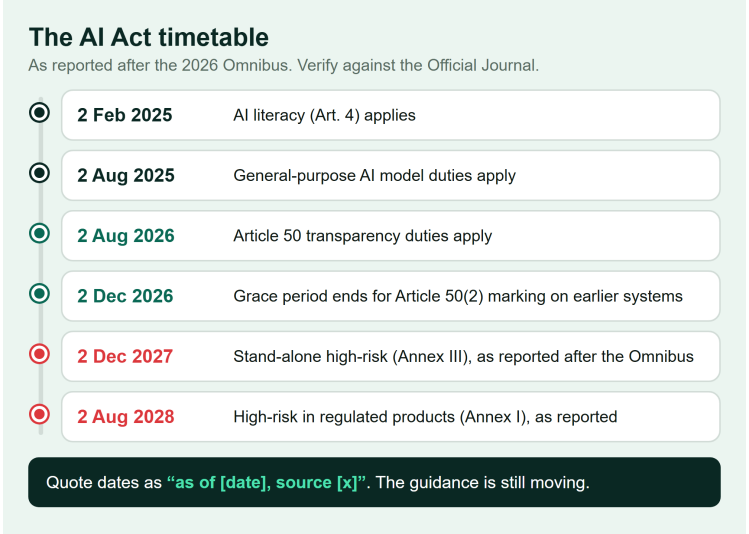
The Act sorts AI systems by risk. In simplified terms:

- **Prohibited practices.** A short list of uses banned outright, such as certain manipulative techniques or social scoring. A small business-software supplier is very unlikely to be here, but should be able to say it has checked.
- **High-risk systems.** Systems in listed areas such as employment and worker management, education, access to essential services, law enforcement and critical infrastructure, plus AI that is a safety component of regulated products. These carry the heaviest obligations: risk management, data governance, documentation, logging, human oversight, accuracy and robustness, and conformity assessment.
- **Transparency obligations.** Duties to disclose AI interaction and to mark certain synthetic content, under Article 50.
- **Minimal risk.** Everything else. No specific obligations under the Act, although other laws still apply.

A key practical step: for each AI feature, ask whether it falls into one of the high-risk areas. A feature that helps rank job applicants, assess students, or decide credit access is a very different conversation from one that drafts appointment reminders. If you are anywhere near a listed area, get advice *before* answering.

The dates: what has moved

The timetable was reshaped in 2026. The "Digital Omnibus on AI" was agreed politically in May 2026 and is reported to have been adopted in the summer, after commentators had warned that unless it was adopted before 2 August 2026 the original dates would apply.[5] As reported by law firms, the main changes were:



The AI Act timetable as reported after the 2026 Omnibus

- **Stand-alone high-risk systems** (the listed areas): moved from 2 August 2026 to **2 December 2027**.
- **High-risk AI embedded in regulated products:** moved from 2 August 2027 to **2 August 2028**.
- **Transparency duties under Article 50:** still applying from **2 August 2026**, with a grace period to 2 December 2026 for marking obligations on generative systems placed on the market earlier.
- **AI literacy (Article 4):** applied from 2 February 2025; the Omnibus is reported to soften it, so that providers and deployers must support staff AI literacy rather than guarantee a particular level.
- **Prohibited practices and general-purpose AI model duties:** not delayed.

Treat these as the reported position and **verify against the Official Journal text** before quoting a date in a contract. Questionnaire answers should say "as of [date]", because the guidance and the practice are still moving.

What to say about AI literacy

Even small suppliers should be able to show that staff who use AI have been told how to use it responsibly. This does not require a course. A short written policy, a 30-minute briefing with an attendance record, and a one-page do-and-don't sheet are a respectable start. The record of the briefing is rung three evidence (Chapter 6).

Answering "Confirm your compliance"

A responsible answer does not say "Yes, we are compliant". It describes a position:

"We have assessed our AI features against the EU AI Act as of [date]. For the reminder and summarisation features we act as provider of the system and as deployer of third-party general-purpose models. Based on our assessment these features are not within the high-risk categories of Annex III and do not involve prohibited practices; [reasoning in one line]. We apply the transparency measures required by Article 50 [describe]. Staff who use AI have been briefed under our AI-use policy [record E-09]. We monitor the Omnibus implementation and will reassess if the features change. This is our own assessment, not a regulator's or third party's finding."

Notice the pieces: role, assessment date, reasoning, specific measures, evidence reference and an honest label on whose assessment it is.

Over-claiming and under-claiming

There are two opposite errors.

- **Over-claiming:** "AI Act compliant", "fully compliant with all EU AI regulations", "certified". The Act does not offer a general certificate to small suppliers, and these phrases invite the question you cannot answer.
- **Under-claiming:** "The Act does not apply to us." It may well apply in part, through transparency duties, literacy support, value-chain information and your role as deployer, even if your features are not high-risk.

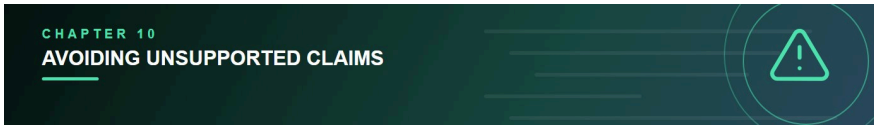
The middle path, a stated role, a reasoned classification and a few specific practices, is both safer and more convincing.

Action list

- ☐ Add "role: provider / deployer / both" to each row of the AI inventory.
- ☐ For each feature, check the high-risk areas and write one line of reasoning.
- ☐ Note the dates you rely on, with source and date checked.
- ☐ Run a 30-minute AI-use briefing and keep the attendance record.

CHAPTER 10

Avoiding Unsupported Claims

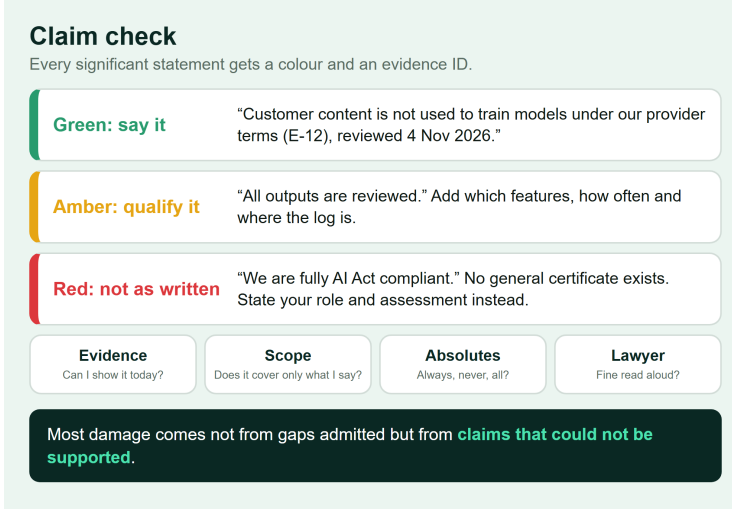


If this book has one chapter that can save a deal, a contract or a reputation, it is this one. **Most damage in AI due diligence does not come from the gaps a supplier admits. It comes from claims it could not support.**

Why unsupported claims matter

A questionnaire answer is not a marketing line. It may be copied into a vendor file, relied on in a contract, repeated to a regulator and read by a lawyer after an incident. Inaccurate statements about security or AI can lead to a lost deal, a termination for misrepresentation, a claim for damages or regulatory attention.

Regulators are also paying attention to AI claims in marketing. The US Federal Trade Commission announced enforcement actions against deceptive AI claims in 2024, and the Securities and Exchange Commission has charged firms for overstating their use of AI, a practice now nicknamed "AI washing".[11][12] The point for a small supplier is not the particular regime. It is that **exaggerated AI and compliance statements are being treated as a real misconduct risk.**



Claim check: green can be shown, amber needs qualifying, red cannot be said as written

The phrases that cause trouble

Some wordings invite problems because they are absolute, vague or unverifiable. Watch for these:

Phrase	The problem	A safer way to say it
"GDPR compliant"	Compliance is continuous, contextual and not certifiable by self-declaration	"We maintain a GDPR programme including DPAs, records of processing and a breach process (E-03, E-04)."
"EU AI Act compliant"	No general certificate; depends on role and features	"We assessed our features against the Act as of [date] (Chapter 9 wording)."
"We never use your data for training"	Absolute; true only if every provider and setting agrees	"Customer content is not used to train models under our provider terms (E-12), reviewed [date]."
"All outputs are human-reviewed"	Fails if any output path skips review	"Outputs of feature X are reviewed before sending; feature Y is sampled (E-15)."
"Bank-grade security" / "military-grade encryption"	Meaningless to a reviewer	"Data is encrypted in transit (TLS 1.2+) and at rest (AES-256)."
"Fully secure" / "unhackable"	Impossible to prove	"We use controls including MFA, least-privilege access and logging (E-06)."
"ISO 27001 certified"	True only for the defined scope	"Our [product] is covered by ISO 27001 certificate no. [x], scope: [y]."
"Zero data retention"	Often true only for one layer	"Provider retains inputs for [n] days for abuse monitoring; we retain outputs for [n] days."
"Bias-free AI"	Cannot be demonstrated	"We test outputs for [specific issue] using [method] and review results [frequency]."

The claim register

The most effective protection is a **claim register**: a single sheet listing every significant statement the company makes about AI, security and compliance, wherever it appears. Appendix D has a template. For each claim, record:

- **The exact wording,** and where it appears (website, deck, questionnaire, contract).
- **The evidence** that supports it, by evidence ID.
- **The owner** who can vouch for it.
- **The last verified date.**
- **The status:** green (supported), amber (needs qualifying) or red (remove or fix).

Start with a half-day sweep: read the website, security page, sales deck, proposals and last three questionnaires, and copy out every sentence that says something about AI, data or compliance. Most companies find a handful of red items on the first pass. Removing or rewording them takes minutes and removes a risk that has been sitting in public.

Four tests before any claim goes out

1. **The evidence test.** Can I point to a document, record or setting that supports this today?
2. **The scope test.** Does the claim cover exactly what I say it covers, with no extra product, entity or time?
3. **The absolute test.** Does it contain "always", "never", "all", "fully", "guaranteed"? If so, can it survive one exception?
4. **The lawyer test.** If the customer's lawyer read this aloud in a dispute, would I be comfortable?

When the truth changes

Claims go stale. A provider changes a setting; a feature adds a new model; an employee leaves the team that owned the answer. When something changes, update the register, then fix every place the old claim appears. If a customer has already received a statement that is no longer true, **tell them**. A correction early is an inconvenience. A correction after an incident is a credibility problem.

Marketing and sales must be inside the loop

Questionnaire claims are only one channel. Sales decks, landing pages and proposals make claims too, and the person who writes them is often not the person who answers the questionnaire. Share the claim register with marketing and sales, and make a simple rule: **a new claim about AI, security or compliance must have an evidence ID before it is published.**

Action list

- ☐ Run a one-day claim sweep across your website, deck and recent questionnaires.
- ☐ Build the claim register (Appendix D) and mark every item green, amber or red.
- ☐ Fix or remove every red item this week.
- ☐ Give marketing and sales the "evidence ID before publishing" rule.

CHAPTER 11

Answering the Questionnaire

Answers written by one accountable person, reviewed by another

When the file finally arrives, you want a process, not a scramble. A good process is simple enough to run on a Tuesday afternoon with one person who also has a day job.

A workflow that works

1. Triage (day 1). Read the whole thing before answering any of it. Note the deadline, the format, how answers will be scored, whether answers become contractual, and any questions that need a lawyer or a decision.

2. Assign (day 1). Give every question an owner. Product answers go to product, security answers to whoever manages security, contract questions to whoever signs. A single coordinator tracks the whole sheet.

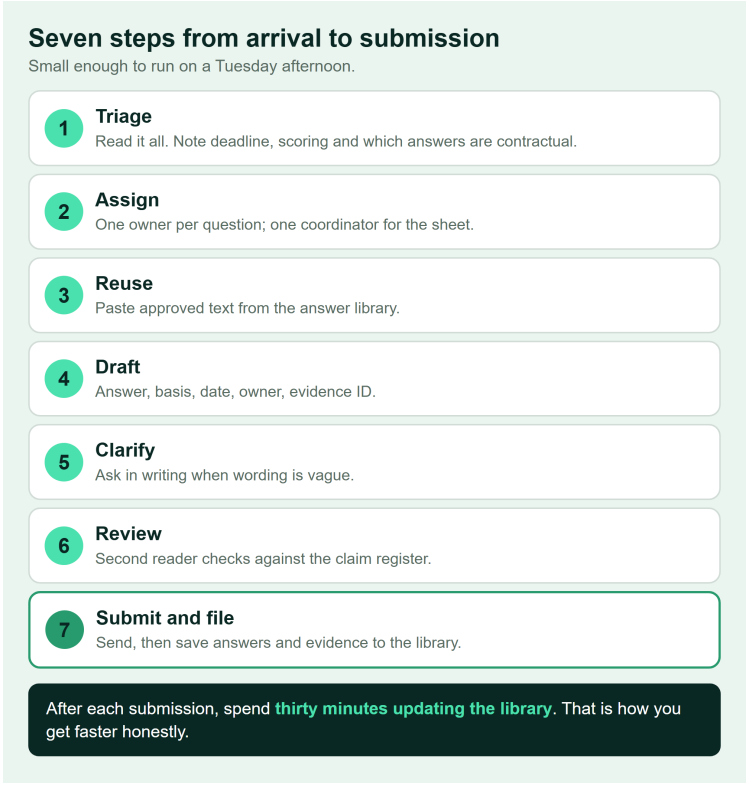
3. Reuse (day 1 to 2). Search your answer library for each question and paste approved text as the starting point. Tag the ones that are new.

4. Draft the new ones (days 2 to 5). Write them using the four elements from Chapter 2: answer, basis, date, owner. Reference an evidence ID.

5. Clarify (in parallel). If a question is ambiguous, ask in writing instead of guessing. Procurement teams generally welcome a precise question, and the reply protects you if the wording was unclear.

6. Review (days 5 to 7). A second person checks every answer against the claim register and the four tests in Chapter 10. Contract-affecting answers go to your lawyer.

7. Submit and file (day 8 onward). Send answers with the agreed evidence. Then save the final version, the evidence list and the date in your library, so the next questionnaire starts further along.



From arrival to submission: a seven-step response process

The answer library

Your biggest time-saver is a living **answer library**: a spreadsheet of approved answers, each with:

- The question in plain words and the family it belongs to (Chapter 2).
- The approved answer text and a short version.
- Evidence IDs.
- Owner and last-review date.
- A "do not reuse if..." note for answers that depend on context.

Treat it with the same discipline as the claim register. Update a library answer whenever the underlying fact changes.

Writing good answers

- **Answer the question asked.** If the question is yes or no, begin with yes or no, and then explain.
- **Be as specific as the evidence allows.** Name the provider, the region, the document, the date.
- **State scope.** "For feature X, as of [date]."
- **Offer, don't flood.** Reference the evidence and offer it under NDA rather than attaching everything.
- **Avoid marketing language.** Reviewers skim past it, and it weakens the specific parts.
- **Keep a consistent voice** across all answers, written by one editor.

Handling "not applicable", "partial" and "no"

Many forms offer a drop-down: Yes, Partial, No, N/A. Use them accurately.

- **Yes** only when the capability is in place, evidenced and in current use.
- **Partial** when part is in place. Say which part and what remains.
- **No** when you do not have it. Add one line of what you do instead, and a date if you are planning it.
- **N/A** only when the question genuinely does not apply. Explain why in a few words, because unexplained N/As look evasive.

Inflating "Partial" into "Yes" is the quickest route to a claim you cannot support.

Good, weak and dangerous

Question: "Do you have a documented AI incident response process?"

> **Dangerous:** "Yes, we have a comprehensive world-class incident response framework."
>
> **Weak:** "We have an incident response policy."
>
> **Strong:** "Partially. Our general security incident procedure (IR-3, v1.2, reviewed 6 Oct 2026) covers AI features and names the owner and escalation path. It includes a customer-notification step within [72] hours of confirming an incident affecting customer data. We tested it in a tabletop exercise on 12 Oct 2026 (record E-18). AI-specific scenarios such as harmful model output are being added by 31 Jan 2027."

The strong answer says "Partially", gives dates, reveals a gap and commits to closing it. It is the one a reviewer trusts.

Time and effort

A first questionnaire may take a week or more even with preparation. A tenth takes a day. The investment is in the library and the evidence, not in the typing. After each one, spend thirty minutes on what the customer pushed back on and update the library. That is how a small company gets quicker without cutting corners.

Action list

- ☐ Set up the answer library with the 20 questions you expect most often (Appendix F).
- ☐ Define the seven-step workflow and who plays each role.
- ☐ Agree a rule: no answer is sent without a second reader.
- ☐ After each submission, update the library within a week.

CHAPTER 12

Building the Trust Pack

A small, current pack of documents beats a large, stale one

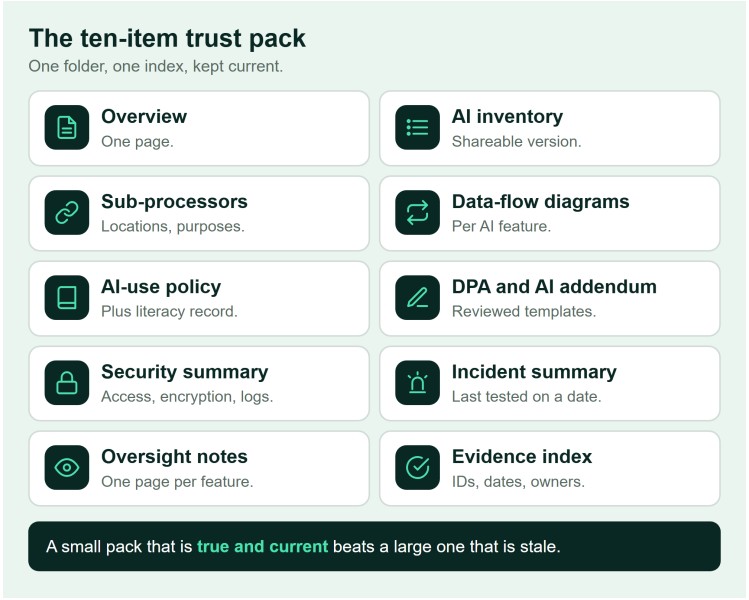
The "trust pack" is the ready-to-share collection of documents that supports your answers. Think of it as a bundle you can send, under NDA, the day a customer asks. The idea has become common enough that practitioner blogs describe ten-document "evidence packs" for AI governance; yours should be as small as truth allows.[3]

What goes in

A sensible starting pack for a small supplier contains:

1. **A one-page overview:** what you do, how AI features work, your role and the key controls.
2. **AI inventory** (the shareable version).
3. **Sub-processor list** with locations and purposes.
4. **Data-flow diagrams** for each AI feature.
5. **AI acceptable-use policy** and a short AI literacy record.
6. **Data processing agreement** and an AI addendum.
7. **Security summary:** access control, encryption, logging, backup, vulnerability management.
8. **Incident response summary** and the date it was last tested.
9. **Oversight descriptions** for each feature.
10. **Evidence index** and, where you hold them, certificates or test summaries.

Ten items, one folder, one index. If a customer wants more, they can ask.



The contents of a small supplier's trust pack

A public trust page

Many suppliers also publish a **trust page** on their website, listing the sub-processors, security practices and data-use positions that are safe to share. It answers many questions before they are asked, and it lets sales say "the page is here" instead of re-sending documents. Two cautions:

- Everything on it falls under the claim register. A trust page is a public statement.
- Date every section. "Last updated 4 November 2026" is a trust signal in itself.

Keeping it alive

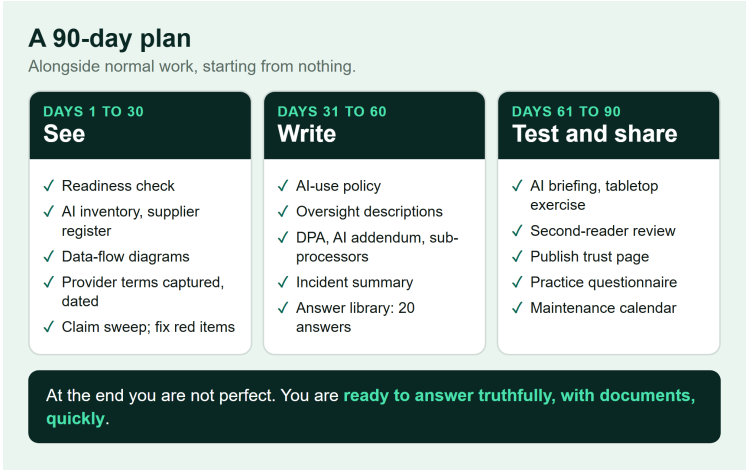
A pack decays. Set a maintenance rhythm that matches your size:

- **Monthly:** check provider change notices and update the sub-processor list.
- **Quarterly:** reread the claim register, check provider settings, refresh the inventory.
- **On any change:** new model, new provider or new feature triggers an update before release.
- **Annually:** review every policy, rerun the incident exercise, retest the oversight sample.

Assign these to a named owner and put them in a calendar. The failure mode is not that the pack is badly written. It is that nobody owns it after the questionnaire is sent.

The 90-day plan

If you start from nothing, here is a realistic way to get to a usable pack in a quarter, alongside normal work.



A 90-day plan for a small supplier starting from nothing

Days 1 to 30: see. Run the readiness check. Build the AI inventory and supplier register. Draw data-flow diagrams. Capture provider terms and training statements with dates. Do the claim sweep and fix red items.

Days 31 to 60: write. Draft the AI acceptable-use policy and oversight descriptions. Prepare the DPA, sub-processor list and AI addendum. Write an incident-response summary. Start the evidence index and the answer library with twenty answers.

Days 61 to 90: test and share. Run an AI-use briefing and a tabletop incident exercise, and keep the records. Have a second person review the library against the claim register. Publish a trust page. Run a practice questionnaire against a free template and note the gaps. Set the maintenance calendar.

At the end you will not be perfect. You will be **ready to answer truthfully, with documents, quickly.** That is the goal.

Using templates and packs

Commercial and free templates can speed things up. Regulation-focused publishers sell question-and-clause packs, and professional bodies publish frameworks.[1] They are useful for two reasons: they show you what buyers may ask, and they give you a structure. Remember three limits. A template is not an assessment of your business. A purchased pack does not make you compliant. And any template's legal wording should be reviewed by your own adviser before you use it in a contract.

Action list

- ☐ Create a trust-pack folder with the ten items above, filling in what exists today.
- ☐ Write the maintenance calendar and assign an owner.
- ☐ Decide whether a public trust page is worth publishing this quarter.
- ☐ Block time on the calendar for days 1 to 30 of the plan.

CHAPTER 13

When the Answer Is "Not Yet"

Sooner or later, a questionnaire asks for something you do not have. No ISO certificate. No penetration test. No written policy on AI procurement. No evidence of human review. This is normal. How you handle it determines whether the deal survives.

Gaps are expected

Procurement teams read hundreds of answers. They know small suppliers do not have everything. What they test is **honesty and direction**: do you know where the gaps are, can you describe them without defensiveness, and do you have a believable plan?

A gap register

"Not yet", turned into a dated plan. Fictional example.

Gap	Risk	Interim control	Plan
No ISO certificate	Weaker independent assurance	Dated self-assessment, scoped	External review, Q2, owner CEO
No review logging	Oversight not provable	Weekly manual sample sheet	Log in product by 31 Jan
Manual provider notices	Late change alerts	Email list and change log	Automate by Q1

Reviewers read hundreds of answers. They test **honesty and direction**, not perfection.

A gap register turns "not yet" into a dated plan

The gap register

Keep a simple register of known gaps (Appendix D includes a column for it):

- **The gap,** in plain words.
- **The risk it creates** for the customer.
- **The interim control,** what you do meanwhile.
- **The plan,** with a named owner and a date.
- **The status.**

Then, when a question exposes a gap, the answer is already written: "*Not yet. Interim control is* X. *We plan to complete* Y *by [date], owner* Z."

Interim controls

An interim control is a practical measure that reduces risk while the full solution is built. Examples:

- No ISO certificate yet, so a self-assessment against the standard's main controls, dated and scoped, with an external review booked.
- No formal human-review logging yet, so a manual weekly sample of outputs recorded in a sheet.
- No automated sub-processor notification, so a manual email list and a published change log.
- No dedicated security staff, so a named owner, an external adviser on retainer and quarterly reviews.

Interim controls turn "no" into "partial", honestly.

Red lines

Some gaps cannot be bridged by a plan. Know your red lines in advance, because under pressure everything looks negotiable.

- **A promise you cannot keep through the chain.** If a customer demands a 24-hour incident notice and your key provider cannot give you one, do not sign it.
- **Unlimited liability for AI output** with no insurance or provider backing.
- **A claim you would have to invent** to complete the form.
- **Use of customer data you do not control,** for example agreeing no training when a tool you rely on cannot guarantee it.
- **Special-category or high-risk use cases** for which you have not assessed the features.

If a customer insists on a red line, the honest response is to decline that term, explain why, and offer the nearest thing you can support. Occasionally it means losing a deal. A signed contract you cannot perform is a worse outcome.

Negotiating a path forward

When a gap matters to the customer, propose options rather than excuses:

- **A phased commitment:** deliver the control by a date, with a review milestone.
- **A scoped deployment:** launch for a lower-risk use first, and extend after the control exists.
- **A shared control:** the customer retains a measure on their side while yours is built.

- **A review right:** the customer may audit or review your progress at agreed points.

Buyers want to approve suppliers, not reject them. A credible path gives them something to put in the file.

After the deal: staying honest

Winning the contract starts a new obligation: your answers become your commitments. Set reminders for every dated promise, and tell the customer when something changes. If an AI incident happens, follow the process you described, notify on time, and treat the questionnaire as the standard you will be judged against. Suppliers that do this tend to become trusted suppliers, and trusted suppliers get renewed.

Action list

- ☐ List your three largest known gaps and write the interim control for each.
- ☐ Write your red lines on one page and share them with whoever negotiates.
- ☐ Put every dated commitment from past questionnaires into a calendar.
- ☐ Decide who tells the customer when a commitment slips.

Conclusion: Before the RFP Arrives

Marta did not win the healthcare group's business with a perfect questionnaire. She won it with a truthful one. It said "Partially" in six places and named the dates. It linked every claim to a document. It stated what the reminder feature was not for. It listed four sub-processors with their regions. The procurement manager's reply, three weeks later, was one line: *"This is the clearest AI response we have received from a supplier of your size."*

Nothing in that answer required a large budget. It required knowing what Tidewell used, writing down what it did with data, being honest about people's role in the loop, and refusing to claim what it could not show.

If you take one idea from this book, take this: **the questionnaire is a mirror, not an exam.** It reflects how well you know your own business. The work of preparing is mostly the work of knowing, and then writing down what you know.

You do not need to do everything at once. Build the inventory this week. Fix the red claims. Start the supplier register. Draft three answers. In ninety days you will be a different kind of supplier, one who says "send it over" and means it.

> **The rule.** Know it. Write it down. Date it. Prove it. Then say it.

APPENDIX A

AI Inventory

Build this as a spreadsheet. One row per AI tool, model or feature, covering both AI inside your product and AI inside your business. Review it quarterly.

Ref	Tool or feature	Provider and location	Purpose	Product or internal	Data level (1 to 4)	Trains on our data?	Contract basis	Role (provider / deployer)	Owner	Last reviewed
A1	Reminder drafting			Product						
A2	Message summaries			Product						
A3	Coding assistant			Internal						
A4	Meeting transcriber			Internal						
A5	Image generator			Internal						
A6	Support chatbot			Both						

Data levels: 1 no business data; 2 internal data; 3 customer content or personal data; 4 special-category or highly sensitive data.

Rule: a tool at level 3 or 4 does not go into use until it has a contract basis, a checked training setting and an owner.

APPENDIX B

Supplier and Sub-Processor Register

One row per third party that provides AI capability or touches customer data.

Ref	Legal entity and country	Service	Data categories	Processing locations	Their sub-processors	DPA status	Security evidence	Last reviewed	Exit route
S1		Model API							
S2		Cloud hosting							
S3		Transcription							
S4		Email delivery							
S5		Analytics							

Provider file checklist (one folder each, every item dated):

- ☐ Terms of service saved as PDF
- ☐ Data processing addendum signed or accepted
- ☐ Training and data-use statement for our plan
- ☐ Security evidence (certificate, report or trust page)
- ☐ Sub-processor list and how changes are announced
- ☐ Region selected and retention settings
- ☐ Incident contact and notification period

Sub-processor list for customers (published or on request): entity, country, service, data categories, processing location, date added.

APPENDIX C

Evidence Index

Every answer ends with evidence IDs. Every evidence file carries a date.

ID	Document	Rung (1 to 4)	Version and date	Owner	Stored at	Supports questions about
E-01	AI inventory	2				Identification
E-02	Sub-processor list	2				Suppliers
E-03	Data processing agreement	2				Data, contract
E-04	Records of processing	2				Data
E-05	AI acceptable-use policy	2				Governance
E-06	Security summary	2				Security
E-07	Incident response procedure	2				Incidents
E-08	Incident exercise record	3				Incidents
E-09	AI briefing attendance record	3				Literacy
E-10	Oversight descriptions	2				Oversight
E-11	Review log sample (redacted)	3				Oversight
E-12	Provider training exclusions	2				Data
E-13	Penetration test summary	4				Security
E-14	Certificate or attestation (scoped)	4				Security, governance

Rung key: 1 statement; 2 policy or procedure; 3 record of something that happened; 4 independent assurance.

APPENDIX D

Claim Register and Gap Register

Part 1: Claim register. Every significant statement about AI, security or compliance, wherever it appears.

Claim (exact wording)	Where used	Evidence ID	Owner	Last verified	Status (green / amber / red)	Action
	Website					
	Sales deck					
	Questionnaire					
	Contract					

Four tests before any claim goes out: evidence, scope, absolutes, lawyer.

Part 2: Gap register. Known gaps and what you are doing about them.

Gap	Risk to the customer	Interim control	Plan	Owner	Due	Status

APPENDIX E

Human Oversight Description Template

Complete one for each AI feature. Keep it to one page.

Feature: _____ **Owner:** _____ **Date:** _____

1. **Oversight position** (in the loop / on the loop / over the loop): _____
2. **Who reviews, and their training:** _____
3. **Authority to reject, edit or stop:** _____
4. **What the reviewer sees** (sources, limits, confidence): _____
5. **What is recorded** (approvals, edits, overrides, timestamps): _____
6. **What happens on error or disagreement** (escalation and timing): _____
7. **How the process is tested** (sampling, audits, user feedback, frequency): _____
8. **Safeguards against automation bias:** _____
9. **Not suitable for:** _____
10. **Transparency to end users** (labelling, disclosure): _____

Evidence kept: _____

APPENDIX F

Forty Common Questions

Use this as the starting spine of your answer library. For each, write the four elements: answer, basis, date, owner.

Identification

1. List all AI systems, models and tools used in delivering the service.
2. Which are built by you, and which are third-party?
3. Which models and versions do you rely on, and who provides them?
4. Do you use AI internally in ways that touch customer data?

Data

5. What customer data is sent to AI models?
6. Is any customer data used to train or improve any model?
7. Where is data processed and stored?
8. How long are prompts, outputs and logs retained?
9. Can customers delete their data, and how fast?
10. Who within your organisation and the providers can access it?

Suppliers

11. List all sub-processors involved in AI features.
12. How do you assess and monitor AI providers?
13. How will you notify us of new sub-processors or model changes?
14. Do you have DPAs with every provider that handles personal data?
15. Do any providers process data outside the EU or EEA, and on what safeguards?

Classification and law

16. How have you classified your AI features under the EU AI Act?
17. Are you a provider, deployer or both?
18. Do any features fall within high-risk categories?
19. How do you meet transparency obligations for AI interaction and generated content?
20. How do you ensure staff AI literacy?

Oversight

21. Describe the human oversight applied to AI outputs.
22. Can a person override or stop the AI?
23. Are reviews recorded?

24. What are the known limitations of the AI features?
25. For what uses is the feature not suitable?

Performance and change

26. How do you test accuracy and quality before release?
27. How do you monitor performance in production?
28. How are model or provider changes managed and communicated?
29. How do you deal with harmful, biased or incorrect outputs?

Security and incidents

30. What access controls and encryption protect data used by AI features?
31. How do you defend against prompt injection and data leakage?
32. Do you log AI interactions, and can customers export logs?
33. What is your incident process, and how quickly do you notify customers?
34. Have you tested the incident process?

Governance and exit

35. Do you have an AI policy, and who owns it?
36. Do you hold any certification (for example ISO/IEC 27001, SOC 2, ISO/IEC 42001)? Give the scope.
37. Do you carry insurance covering AI-related claims?
38. What happens to our data when the contract ends?
39. Will you cooperate with our audits and provide documentation we need?
40. Confirm your compliance with the EU AI Act.

Question 40 deserves care: use the wording pattern from Chapter 9, not a one-word answer.

Glossary

Annex III. The list of high-risk areas in the EU AI Act, such as employment, education and access to essential services.

Automation bias. The tendency of human reviewers to accept machine outputs without proper scrutiny.

Controller. The organisation that decides why and how personal data is processed.

Deployer. An organisation that uses an AI system under its own authority in a professional context.

DPA. Data processing agreement: the contract between controller and processor required by GDPR Article 28.

Evidence ladder. The four levels of proof used in this book: statement, policy, record and independent assurance.

General-purpose AI model. A broadly capable model, such as a large language model, that can be built into many systems.

Human in, on and over the loop. Three positions for oversight: approving each output, monitoring and intervening, and governing the system's design and limits.

ISO/IEC 42001. The certifiable international standard for AI management systems.

Processor. An organisation that processes personal data on behalf of a controller.

Provider. An organisation that develops an AI system and places it on the market or into service under its own name.

Sub-processor. A processor engaged by another processor to help deliver a service.

Trust pack. The ready-to-share set of documents that supports a supplier's questionnaire answers.

A Note on GDPRGard.eu

GDPRGard publishes free tools, guides and articles to help small businesses understand data-protection duties in plain English, including how to map data sharing, handle a data breach, review a processor contract and respond to rights

requests. Visit **gdprgard.eu** for current guidance, templates and updates to the topics in this book.

About the Author

Zirlandia Milkovic writes practical, plain-English guides on data protection, cyber-security, AI and building a business with confidence. She believes security is not a barrier to ambition but a foundation of trust, and that nobody should need a technical degree to protect their customers or to win the larger customers who ask hard questions.

She is the author of a series of business guides, including *GDPR Made Simple for Women Founders*, and her work focuses on turning complex rules and fast-moving threats into simple steps, checklists and templates that busy people can actually use. She is also behind **GDPRGard**, a growing collection of free GDPR tools, guides and articles for small businesses, available at gdprgard.eu.

Before the RFP Arrives grew out of a simple observation: small suppliers adopt AI quickly, win bigger customers, and then discover that nobody ever taught them how to describe that adoption on paper. If this guide helped you, an honest review where you bought it helps other readers find it.

Visit **gdprgard.eu** for free tools, articles and updates.

Notes and Sources

1. Regulation AI, "AI Vendor Due Diligence Pack: 32 Questions and Contract Clauses", working template, updated 6 August 2026, €129 excl. VAT: 32 questions, eight contract clauses (cooperation, Annex IV documentation, change notification, log export and retention, serious incidents, bias and data governance, use of customer data for training, exit); regulation-ai.eu/en/toolkits/vendor-due-diligence (page read). The page is editorial content and states it is not legal advice. Mentioned as an example of the market, not an endorsement.
2. Gartner, abstract dated 3 September 2026 describing a vendor evaluation kit aligned with ISO/IEC 42001, the NIST AI RMF and the EU AI Act (search summary of the abstract read; full report is paywalled and was not read).
3. Peony, "AI Governance Due Diligence (2026): The 10-Artifact Evidence Pack" (commercial blog, summary read via search; treated as one perspective, not a standard).
4. Regulation (EU) 2024/1689 (the AI Act), including Article 4 (AI literacy), Article 14 (human oversight), Article 25 (value chain responsibilities), Article 26 (deployer obligations), Article 50 (transparency) and the general-purpose AI model provisions (working knowledge; read the Official Journal text for exact wording and current numbering).
5. Gibson Dunn, client alert "EU AI Act Omnibus Agreement: Postponed High-Risk Deadlines and Other Key Changes", 27 May 2026 (read): provisional agreement; Annex III high-risk moved from 2 August 2026 to 2 December 2027; Annex I from 2 August 2027 to 2 August 2028; Article 50 disclosure duties remain from 2 August 2026, with a grace period to 2 December 2026 for Article 50(2) marking on systems placed on the market before 2 August 2026; Article 4 softened to a duty to support AI literacy. The alert predates final adoption. Other law-firm and trade commentary found by search reported Council approval around 30 June 2026 and adoption thereafter; the Official Journal reference was not independently confirmed for this book. Check the final text before quoting any date.
6. Regulation (EU) 2016/679 (GDPR), Articles 28 (processors and sub-processors), 30 (records of processing), 32 (security), 35 (data protection impact assessment) and 44 to 49 (transfers) (working knowledge; read the text).
7. Directive (EU) 2022/2555 (NIS2), Article 21(2)(d), supply-chain security; Regulation (EU) 2022/2554 (DORA), contractual requirements for ICT third-party service providers (working knowledge; read the texts; applicability depends on the customer's sector).
8. ISO/IEC 42001:2023, AI management systems; ISO/IEC 27001, information security management; SOC 2 reports under AICPA criteria. Commentary that ISO/IEC 42001 certification does not by itself establish EU AI Act conformity, and that certification should come from an accredited body (secondary summaries read via search; read the standards' scope statements).
9. NIST, Artificial Intelligence Risk Management Framework (AI RMF 1.0) and the Generative AI Profile, NIST AI 600-1, July 2024. Voluntary guidance; there is no NIST certification (working knowledge; secondary summaries read).
10. Cloud Security Alliance, AI Controls Matrix (AICM), v1.0 2025 and v1.1 announced July 2026; 18 domains; control count reported as 243 in v1.0 and about 247 in v1.1 by different sources; mapping to ISO/IEC 42001; foundation of STAR for AI (CSA pages and trade coverage read via search; the control count is not given in the book for that reason).

11. US Federal Trade Commission, announcement of enforcement actions against deceptive AI claims ("Operation AI Comply"), September 2024 (working knowledge; read the FTC press release).
12. US Securities and Exchange Commission, March 2024 settled charges against two investment advisers for false statements about their use of AI, widely described as "AI washing" (working knowledge; read the SEC release).
13. European Data Protection Board, Opinion 28/2024 on certain data protection aspects related to the processing of personal data in the context of AI models, December 2024 (working knowledge; read the opinion).
14. European Data Protection Board, Guidelines 07/2020 on the concepts of controller and processor in the GDPR (working knowledge; read the guidelines).
15. European Commission, Implementing Decision (EU) 2021/914 (standard contractual clauses) and the EU–US Data Privacy Framework adequacy decision of 10 July 2023; the framework has faced legal challenge and its current status should be checked (working knowledge).

Not verified by the author: the final Official Journal reference and exact article numbering of the 2026 AI Omnibus; the content of the full Gartner report; the current features and prices of any commercial toolkit; the current terms, retention periods and training exclusions of any AI provider, which change often and must be read from the provider's own pages; whether and how any particular customer, insurer or regulator will treat the practices described here; and whether the Digital Omnibus changed any obligation for small and mid-cap companies, which the sources read did not address. The story of Tidewell Software, Marta, the healthcare group and every example answer are fictional.